

(一) Centos7安全基线

0x01 初始设置

1. 文件系统配置:
2. 安全启动设置:
3. 强制访问控制:

0x02 服务配置

1. 时间同步设置:

0x03 网络配置

1. hosts设置:
2. 防火墙配置

0x04 审计设置

1. 审计配置文件的设置
2. 审计规则文件的设置

0x05 日志设置

0x06 认证授权

1. 配置cron:
2. 配置SSH:
3. 配置PAM:
4. 用户账户和环境设置:

0x07 系统维护

1. 重要文件权限:
2. 用户和组设置:

(二) Windows2012安全基线

0x01 账户策略

0x02 审计策略

0x03 用户权限分配

0x04 安全选项

0x05 端口安全

0x06 系统安全

(三) MSSQL2016部署规范

0x01 安装更新和补丁

0x02 减少受攻击面

0x03 认证和授权

0x04 密码策略

0x05 审计和日志

0x06 加密

0x07 扩展存储

(四) MySQL5.6部署规范

0x01 操作系统级别配置

0x02 安装和计划任务

0x03 权限设置

0x04 常规设置

0x05 MySQL权限

0x06 审计和日志

0x07 身份认证

(五) 中间件部署规范

0x01 Nginx安全部署规范

1. 隐藏版本号
2. 开启HTTPS
3. 限制请求方法
4. 拒绝某些User-Agent
5. 利用referer图片防盗链
6. 控制并发连接数
7. 设置缓冲区大小防止缓冲区溢出攻击
8. 添加Header头防止XSS攻击

9. 添加其他Header头

0x02 Tomcat安全部署规范

1. 更改Server Header
2. 保护telnet管理端口
3. 保护AJP连接端口
4. 删除默认文档和示例程序
5. 隐藏版本信息（需要解jar包）
6. 专职低权限用户启动tomcat
7. 文件列表访问控制
8. 脚本权限回收

0x03 Apache安全部署规范

1. 专职低权限用户运行Apache服务
2. 目录访问权限设置
3. 日志设置
4. 只允许访问web目录下的文件
5. 禁止列出目录
6. 防范拒绝服务
7. 隐藏版本号
8. 关闭TRACE功能
9. 绑定监听地址
10. 删除默认安装的无用文件
11. 限定可以使用的HTTP方法

0x04 IIS安全部署规范

1. 限制目录的执行权限
2. 开启日志记录功能
3. 自定义错误页面
4. 关闭目录浏览功能
5. 停用或删除默认站点
6. 删除不必要的脚本映射
7. 专职低权限用户运行网站
8. 在独立的应用程序池中运行网站

0x05 Redis安全部署规范

1. 专职低权限用户启动redis
2. 限制redis配置文件的访问权限
3. 更改默认端口
4. 开启redis密码认证
5. 禁用或者重命名危险命令
6. 禁止监听在公网IP
7. 开启保护模式

0x06 RabbitMQ规范

1. 专职低权限用户启动RabbitMQ
2. 配置SSL证书
3. 开启HTTP后台认证
4. 删除或修改默认的guest用户和密码
5. RabbitMQ的web ui插件存在一些安全漏洞

@author: jerrybirdJC0o0l

@wechat: JC_SecNotes

@wechat: JC0o0l

@GitHub: github.com/chroblert/assetmanage

(一) Centos7安全基线

0x01 初始设置

1. 文件系统配置：

1.1 将/tmp挂载至一个单独的分区

1.2 /tmp挂载时指定 `noexec`：不允许运行可执行文件

该选项使得/tmp目录下的二进制文件不可被执行

1.3 /tmp挂载时指定 `nosuid`

该选项使得/tmp目录下的文件或目录不可设置Set-UID和Set-GID标志位，能够防止提权。

2. 安全启动设置：

2.1 设置bootloader的配置文件的权限为 `600`

该配置文件包含了系统启动时的引导信息，该选项可防止该文件被随意读写。

2.2 设置bootloader的密码 【建议】

进入boot loader设置界面需要输入密码

2.3 为单用户启动认证机制

可防止在不知密码的情况下更改root密码

3. 强制访问控制：

3.1 安装SELinux 【建议】

3.2 设置SELinux的状态为 `enforcing` 【建议】

3.3 设置SELinux的 `policy` 为 `targeted` 【建议】

0x02 服务配置

1. 时间同步设置：

1.1 开启时间同步服务

时间的统一可便于入侵日志的检测分析

1.2 不安装 `x-windows` 系统：即不使用可视化界面

X window用于提供用户登录的图形化界面

0x03 网络配置

1. hosts设置：

1.1 配置 `/etc/hosts.allow` 文件

指定哪些IP可以连接到本主机

1.2 配置 `/etc/hosts.deny` 文件

1.3 配置 `/etc/hosts.allow` 文件权限为 `0644`

1.4 配置 `/etc/hosts.deny` 文件的权限为 0644

2. 防火墙配置

2.1 安装 `iptables`

2.2 设置各个 `chain` 的默认策略为 `drop`

0x04 审计设置

1. 审计配置文件的设置

1.1 安装并使用 `auditd`

1.2 配置记录审计日志的文件大小：8M 【建议】

1.3 配置记录审计日志的文件个数：5 【建议】

1.4 单个审计日志文件大小达到设定的值时触发的动作为：`keep_logs/rotate` 【建议】

1.5 磁盘空间满后触发的动作为：`rotate` 【建议】

2. 审计规则文件的设置

2.1 审计更改日期和时间的操作

2.2 审计更改用户/组信息的操作

2.3 审计更改系统网络环境的操作

2.4 审计更改系统强制访问控制的操作

2.5 审计登入登出系统的事件

2.6 审计未授权情况下企图访问文件未成功的事件

2.7 审计使用提权命令的操作

2.8 审计 `sudoers` 文件的变更

2.9 确保审计日志文件 `audit.log` 的规则，在系统 重启前不能改变

0x05 日志设置

1. 安装并启用 `rsyslog`

0x06 认证授权

1. 配置 `cron`:

1.1 开启 `cron` 服务

1.2 配置

`/etc/crontab`, `/etc/cron.hourly`, `/etc/cron.daily`, `/etc/cron.weekly`, `/etc/cron.monthly`, `/etc/cron.d` 文件的权限为 0700

1.3 设置 `cron.allow`：只允许特定的用户可以使用 `cron`

2. 配置 `SSH`:

2.1 配置 `/etc/ssh/sshd_config` 文件的权限为 0600

2.2 关闭 `X11Forwarding`

X11Forwarding用于图形转发

2.3 设置最大认证尝试次数: 4

2.4 开启 IgnoreRhosts: 不启用基于主机的认证

该选项决定通过RhostsRSAAuthentication或HostbasedAuthentication验证的时候是否使用.rhosts和.shosts文件

2.5 关闭 HostbasedAuthentication: 关闭基于主机的认证

2.6 禁止使用root直接登录: PermitRootLogin no

2.7 禁止使用空密码登录: PermitEmptyPasswords no

2.8 禁止用户环境: PermitUserEnvironment no

该选项决定SSH是否可以使用环境变量, 若启用, 则可能通过LD_PRELOAD绕过安全限制

2.9 设置使用的MAC算法:

```
1 hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,umac-128etm@openssh.com,hmac-sha2-512,hmac-sha2-256,umac-128@openssh.com,curve25519sha256@libssh.org,diffie-hellman-group-exchange-sha256
```

2.10 设置空闲超时时间:180秒 ClientAliveInterval 180

2.11 设置一次登录花费时间: 120秒 LoginGraceTime 120

2.12 SSH LogLevel设置为 INFO , LogLevel INFO

2.13 SSH使用v2安全协议: Protocol 2

2.14 设置能够同时连接到服务器的Client数量: 3, ClientAliveCountMax 3

2.15 更改SSHD端口: 10086, Port 10086

3. 配置PAM:

3.1 密码长度最少位数: 12

3.2 密码中最少字符类型数: 3

3.3 配置密码锁定

3.4 配置密码重用限制: 不使用最近5次的密码

3.5 配置密码hash算法: SHA512

4. 用户账户和环境设置:

4.1 密码有效时间: 90天

4.2 密码更改最短间隔: 7天

4.3 密码过期警告: 7天

4.4 自动禁用特定时间内没有活动的账号: 365天

4.5 配置系统账号的无法登录

4.6 配置root账号默认群组的GID为0

4.7 配置shell超时关闭会话时间：900

4.8 配置可以使用 su 命令的用户

0x07 系统维护

1. 重要文件权限：

```
1 /etc/passwd 0644 uid 0 gid 0
2 /etc/shadow 0000 uid 0 gid 0
3 /etc/group 0644 uid 0 gid 0
4 /etc/gshadow 0000 uid 0 gid 0
5 /etc/passwd- 0644 uid 0 gid 0
6 /etc/shadow- 0000 uid 0 gid 0
7 /etc/group- 0644 uid 0 gid 0
8 /etc/gshadow- 0000 uid 0 gid 0
```

2. 用户和组设置：

2.1 不允许密码为空的账号

2.2 只允许root账号的UID为0

2.3 设置path环境变量中的目录只有 owner 可写，group 及 other 都没有 w 的权限

2.4 设置所有用户都有家目录

若用户没有家目录，则登录时会进入 /，并且没有写入文件的权限，也不会拥有环境变量

2.5 设置所有用户家目录的权限为 0750

2.6 设置所有用户家目录的 owner 都为其自身

2.7 设置用户家目录内以 . 开头的文件，只有 owner 可写，group 及 other 都没有 w 的权限

2.8 确保没有 .netrc, .rhosts, .forward 文件

2.9 确保所有在 /etc/passwd 中的组都在 /etc/group

2.10 确保每个用户的UID都不同

2.11 确保每个组的GID都不同

2.12 确保用户名唯一

2.13 确保组名唯一

(二) Windows2012安全基线

0x01 账户策略

1.1 密码策略

[+]确保 强制密码历史 值为5或更高

PasswordHistorySize=5

[+]确保 密码最长使用期限 值为90天或更少，但不为0

MaximumPasswordAge=90

[+]确保 密码最短使用期限 值为1或更多

MinimumPasswordAge=1

[+]确保 密码必须符合复杂性要求 值为 enabled

PasswordComplexity=1

[+]确保 用可还原的加密来存储密码 值为 Disabled

ClearTextPassword=0

[+]确保 密码长度最小值 值为8或更高

MinimumPasswordLength=8

1.2 账户锁定策略

[+]确保 账户锁定时间 值为15分钟或更长

LockoutDuration=15

[+]确保 账户锁定阈值 值为5或更少，但不为0

LockoutBadCount=5

[+]确保 重置账户锁定计数器 值为15分钟或更多，但值要小于 Account lockout duration 的值

ResetLockoutCount=15

0x02 审计策略

[+]审核策略更改：成功

AuditPolicyChange

[+]审核登录事件：成功，失败

AuditLogonEvents

[+]审核对象访问：成功

AuditObjectAccess

[+]审核进程跟踪：成功，失败

AuditProcessTracking

[+]审核目录服务访问：成功，失败

AuditDSAccess

[+]审核系统事件：成功，失败

AuditSystemEvents

[+]审核帐户登录事件：成功，失败

AuditAccountLogon

[+]审核帐户管理：成功，失败

AuditAccountManage

值的含义：

Setting value	Explanation
0	Indicates that this setting is set to None.
1	Indicates that this setting is set to Success Audits Only.
2	Indicates that this setting is set to Failure Audits Only.
3	Indicates that this setting is set to Success and Failure Audits.
4	Indicates that this setting is set to None.

0x03 用户权限分配

[+]确保 作为受信任的呼叫方访问凭据管理器 值为空，没有设置任何用户

SeTrustedCredManAccessPrivilege

如果授予该帐户此权限，则该帐户的用户可以创建一个调用凭据管理器的应用程序，并返回另一个用户的凭据

[+]确保 以操作系统方式执行 值为空，没有设置任何用户。

SeTcbPrivilege

被授予该权限的用户可以完全控制该计算机

[+]确保 将工作站添加到域 值仅为特定的用户或用户组,不能有513, 514, 515

SeMachineAccountPrivilege

该选项决定哪些用户具有将工作站添加到域的权限

[+]确保 创建全局对象 值为空 【X】

SeCreateGlobalPrivilege

[+]确保 拒绝作为批处理作业登录 包含 Guests

SeDenyBatchLogonRight

该选项决定哪些用户不能使用任务计划管理程序，有可能会消耗大量程序，造成DoS

[+]确保 拒绝以服务身份登录 包含 Guests

SeDenyServiceLogonRight

该选项决定哪些用户可以将进程注册为服务

[+]确保 拒绝本地登录 包含 Guests

SeDenyInteractiveLogonRight

[+]确保 从远程系统强制关机 值为 administrators 本地组和 s-1-5-32-549 (域控的一个内置组)

SeRemoteShutdownPrivilege

[+]确保 修改对象标签 值为空

SeRelabelPrivilege

该选项决定哪些用户具有更改其他对象完整性标签的权限

[+]确保 同步目录服务数据 值为空

SeSyncAgentPrivilege

该选项决定哪些用户具有同步域控上目录服务器数据的权限

0x04 安全选项

[+]确保 账户：来宾账户状态 值为已禁用

EnableGuestAccount=0

[+]确保 账户：限制使用空密码的本地账户只能使用控制台登录 值为 Enabled

MACHINE\System\CurrentControlSet\Control\Lsa\LimitBlankPasswordUse=4,1

启用该选项，则没有密码的用户只能在本地进行登录

[+]配置 账户：重命名系统管理员账户

NewAdministratorName="NewAdministrator"

[+]配置 账户：重命名来宾账户

NewGuestName="NewGuestName"

[+]确保 交互式登录：不显示上次登录用户名 值为 Enabled

MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\DontDisplayLastUserName=4,1

[+]确保 交互式登录：无须按Ctrl+Alt+Del 值为 Disabled

MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\DisableCAD=4,0

[+]确保 交互式登录：计算机不活动限制 值为900秒或更少

MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\InactivityTimeoutSecs=4,900

[+]确保 Microsoft 网络客户端：将未加密的密码发送到第三方 SMB 服务器 值为 Disabled

MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parameters\EnablePlainTextPassword=4,0

该选项决定是否明文发送用户名和密码

[+]确保 Microsoft网络服务器：暂停会话前所需的空闲时间数量 值为15分钟或更少，但不为0

MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\AutoDisconnect=4,15

[+]确保 网络安全：再下一次改变密码时不存储LAN管理器哈希值 值为 Enabled

MACHINE\System\CurrentControlSet\Control\Lsa\NoLMHash=4,1

[+]确保 网络访问：允许匿名SID/名称转换 值为 Disabled

LSAAnonymousNameLookup = 0

该选项决定一个匿名用户是否可以根据用户名请求到SID，或者根据SID请求到用户名

[+]确保 网络访问：不允许SAM账户的匿名枚举 值为 Enabled

```
MACHINE\System\CurrentControlSet\Control\Lsa\RestrictAnonymous=4,1
```

该选项决定一个匿名用户是否可以枚举存在于SAM中工作组用户名或者域用户账户名

[+]确保 网络访问：不允许SAM账户和共享的匿名枚举 值为 Enabled

```
MACHINE\System\CurrentControlSet\Control\Lsa\RestrictAnonymous=4,1
```

该选项决定一个匿名是否可以枚举存在于SAM中的用户以及共享

[+]确保 关机：允许系统在未登录前关机 值为 Disabled

```
MACHINE\System\CurrentControlSet\Control\Session Manager\Memory  
Management\ClearPageFileAtShutdown=4,0
```

0x05 端口安全

[+]确保 RDP 端口不为 3389，改为 8888

```
for /f "skip=2 tokens=3" %i in ('REG query  
HKLM\SYSTEM\CurrentControlSet\Control\Terminal" "Server\winStations\RDP-Tcp /v  
PortNumber') do @echo %i
```

0x06 系统安全

关闭windows自动播放功能

```
reg add HKCU\Software\Microsoft\windows\CurrentVersion\Policies\Explorer /v  
NoDriveTypeAutoRun /t REG_DWORD /d 233 /f
```

关闭 TCP/IP NetBIOS Helper 服务

提供TCP/IP(NetBT)服务商的NetBIOS上的NetBIOS和网络上客户端的NetBIOS名称解析的支持，从而使用户能够共享文件、打印和登录到网络

关闭 Print Spooler 服务

管理所有本地和网络打印队列及控制所有打印工作

关闭 Remote Registry 服务

使远程用户能修改此计算机上的注册表设置

删除系统默认共享

如C\$

(三) MSSQL2016部署规范

0x01 安装更新和补丁

1. 确保安装了最新的SQL Server service Pack和所有的Hotfixes已经安装 【建议】

```
1 | select SEVERPROPERTY('ProductLevel') as  
   SP_installed,SERVERPROPERTY('ProductVersion') as Version;
```

2. 确保使用了 `Single-Function Member Servers` :该服务器上只作为MSQQL服务器使用 【建议】

0x02 减少受攻击面

1. 确保 `Ad Hoc Distributed Queries` 服务器配置选项值为 0

该选项允许用户查询数据并在外部数据源上执行语句

```
1 SELECT name,CAST(value as int) as value_configured,CAST(value_in_use as int)
   as value_in_use FROM sys.configurations WHERE name = 'Ad Hoc Distributed
   Queries';
```

2. 确保 `CLR Enabled` 服务器配置选项值为 0

该选项指定哪些用户组件可以被SQL Server 运行

```
1 SELECT name,CAST(value as int) as value_configured,CAST(value_in_use as int)
   as value_in_use FROM sys.configurations WHERE name = 'clr enabled';
```

3. 确保 `Cross DB Ownership Chaining` 服务器配置选项值为 0

该选项控制在instance级别上所有数据库之间的跨数据库的所有权的链。

开启后，可能造成信息泄露

```
1 SELECT name,CAST(value as int) as value_configured,CAST(value_in_use as int)
   as value_in_use FROM sys.configurations WHERE name = 'cross db ownership
   chaining';
```

4. 确保 `Database Mail XPs` 服务器配置选项值为 0

该选项控制SQL Server生成和传输邮件信息的能力

```
1 SELECT name,CAST(value as int) as value_configured,CAST(value_in_use as int)
   as value_in_use FROM sys.configurations WHERE name = 'Database Mail XPs';
```

5. 确保 `Ole Automation Procedures` 服务器配置选项值为 0

该选项控制OLE自动化对象能否在T-SQL批处理语句中执行。

```
1 SELECT name,CAST(value as int) as value_configured,CAST(value_in_use as int)
   as value_in_use FROM sys.configurations WHERE name = 'Ole Automation
   Procedures';
```

6. 确保 `Remote Access` 服务器配置选项值为 0:

该选项控制位于远程服务器上的本地存储过程或者位于本地服务器的远程存储过程的执行。

7. 确保 `Remote Admin Connections` 服务器配置选项值为 0:

该选项控制位于远程计算机上的客户端应用是否能使用DAC(传用管理员连接)，用于故障排查

8. 确保 `Scan For Startup Procs` 服务器配置选项值为 0:

开启该选项会使SQL Server扫描和自动运行所有被设置为在服务开启时运行的存储过程

9. 确保 `Trustworthy` 数据库属性值为 off

该选项允许数据库对象在某些情况下访问其他数据库中的对象

```
1 SELECT name FROM sys.databases WHERE is_trustworthy_on = 1 AND name != 'msdb';
```

10. 确保只使用了必须的协议 【建议】

```
1 sql server configuration manager -> sql server network configuration
```

11. 确保SQL Server使用了非标准端口 【建议】

```
1 DECLARE @value nvarchar(256)
2 EXECUTE master.dbo.xp_instance_regread
3     N'HKEY_LOCAL_MACHINE',
4     N'SOFTWARE\Microsoft\Microsoft SQL
5     Server\MSSQLServer\SuperSocketNetLib\Tcp\IPAll',
6     N'TcpPort',
7     @value OUTPUT,
8     N'no_output';
9 SELECT @value as TCP_Port WHERE @value='1433';
```

12. 确保生产环境中SQL Server的Hide Instance 选项值为 Yes，集群中为 No

生产环境中的非群集sql服务器实例应指定为隐藏，以防止SQL Server 浏览服务发布广告

```
1 DECLARE @getValue INT;
2 EXEC master.sys.xp_instance_regread
3     @rootkey=N'HKEY_LOCAL_MACHINE',
4     @key=N'SOFTWARE\Microsoft\Microsoft SQL
5     Server\MSSQLServer\SuperSocketNetLib',
6     @value_name=N'HideInstance',
7     @value=@getValue OUTPUT;
8 SELECT @getValue;
```

13. 确保 sa 账户已禁用，不允许登录

```
1 SELECT name,is_disabled FROM sys.server_principals WHERE sid=0x01 AND
2 is_disabled=0;
```

14. 重命名 sa 账户

```
1 SELECT name FROM sys.server_principals WHERE sid=0x01;
```

15. 确保 xp_cmdshell 服务器配置选项值为 0

该选项控制是否可以使用xp_cmdshell这个可以调用系统的命令并在sql客户端返回执行结果的扩展存储过程。

```
1 SELECT name,CAST(value as int) as value_configured,CAST(value_in_use as int)
2 as value_in_use FROM sys.configurations WHERE name = 'xp_cmdshell';
```

16. 确保在包含的数据库上的 AUTO_CLOSE 值为 OFF

该选项用于决定在连接终止后，给定数据库是否关闭。

```
1 | SELECT name,containment,containment_desc,is_auto_close_on FROM sys.databases
   | WHERE containment <> 0 and is_auto_close_on = 1;
```

17. 确保不存在 sa 这个账户

```
1 | SELECT principal_id,name FROM sys.server_principals WHERE name = 'sa';
```

0x03 认证和授权

1. 确保 Server Authentication 属性设置为 Windows Authentication Mode

使用 Windows Authentication 去验证连接

```
1 | SELECT SERVERPROPERTY('IsIntegratedSecurityOnly') as [login_mode]; //1
```

2. 确保移除了 guest 用户在除了 master, msdb, tempdb 数据库之外数据库上的 CONNECT 权限

移除 guest 用户连接 SQL Server 数据库的权限，除了 master, msdb, tempdb 数据库

```
1 | use <database_name>;
2 | GO
3 | SELECT DB_NAME() AS DatabaseName, 'guest' as Database_User, [permission_name],
   | [state_desc] FROM sys.database_permissions WHERE [grantee_principal_id] =
   | DATABASE_PRINCIPAL_ID('guest') AND [state_desc] LIKE 'GRANT%' AND
   | [permission_name] = 'CONNECT' AND DB_NAME() NOT IN
   | ('master', 'tempdb', 'msdb');
4 | -- no rows should be returned
```

3. 确保 SQL Server 数据库中的 Orphaned Users 被废弃了

没有在服务器实例上为其定义相应的 sql 服务器登录名或没有正确定义数据库用户的数据库用户，无法登录到该实例，该用户就称之为 Orphaned User，应该将其删除。

```
1 | use <database_name>;
2 | go
3 | EXEC sp_change_users_login @Action='Report';
4 | -- no rows should be returned
```

4. 确保在包含的数据库中未使用 SQL 身份验证

包含的数据库不对 SQL 身份验证的用户强制实施密码复杂性规则

```
1 | use <database_name>;
2 | go
3 | SELECT name as DBUser FROM sys.database_principals WHERE name NOT IN
   | ('dbo', 'Information_Schema', 'sys', 'guest') AND type IN ('U', 'S', 'G') AND
   | authentication_type = 2;
4 | -- no rows should be returned
```

5. 确保 SQL Server 的 MSSQL Service 账户不是管理员 【建议】

默认实例的 MSSQLSERVER 服务或者一个有名字实例的 MSSQL\$<InstanceName> 服务使用的账户或者SID不应该是Windows Administrator组的成员。

- 1 | 检查服务的账户和SID是否是windows Administrators组的成员

6. 确保SQL Server的SQLAgent Service账户不是管理员 【建议】

默认实例的 SQLSERVERAGENT 服务或者一个有名字实例的 SQLAGENT\$<InstanceName> 服务使用的账户或者SID不应该是Windows Administrator组的成员。

- 1 | 检查服务的账户和SID是否是windows Administrators组的成员

7. 确保SQL Server的Full-Text Service账户不是管理员 【建议】

默认实例的 MSSQLFDLauncher 服务或者一个有名字实例的 MSSQLFDLauncher\$<InstanceName> 服务使用的账户或者SID不应该是Windows Administrator组的成员。

- 1 | 检查服务的账户和SID是否是windows Administrators组的成员

8. 确保 public 服务器角色只授予了默认的权限

public 是一个包含所有登录名的特殊的固定服务器角色。与其他的固定角色不同，public 可以改变权限。

- ```
1 | SELECT * FROM master.sys.server_permissions WHERE (grantee_principal_id =
 | SUSER_SID(N'public') and state_desc LIKE 'GRANT%') AND NOT(state_desc =
 | 'GRANT' and [permission_name] = 'VIEW ANY DATABASE' and class_desc =
 | 'SERVER') AND NOT(state_desc = 'GRANT' and [permission_name] = 'CONNECT' and
 | class_desc = 'ENDPOINT' and major_id = 2) AND NOT (state_desc = 'GRANT' and
 | [permission_name] = 'CONNECT' and class_desc = 'ENDPOINT' and major_id = 3)
 | AND NOT (state_desc = 'GRANT' and [permission_name] = 'CONNECT' and
 | class_desc = 'ENDPOINT' and major_id = 4) AND NOT (state_desc = 'GRANT' and
 | [permission_name] = 'CONNECT' and class_desc = 'ENDPOINT' and major_id = 5);
2 | -- should not return any rows
```

## 9. 确保Windows BUILTIN 组不是SQL登录名

- ```
1 | SELECT pr.[name], pe.[permission_name], pe.[state_desc] FROM
  | sys.server_principals pr JOIN sys.server_permissions pe ON pr.principal_id =
  | pe.grantee_principal_id WHERE pr.name like 'BUILTIN%';
2 | -- should not return any rows
```

10. 确保Windows local 组不是SQL登录名

- ```
1 | use [master]
2 | go
3 | SELECT pr.[name] as LocalGroupName,pe.[permission_name],pe.[state_desc] FROM
 | sys.server_principals pr JOIN sys.server_permissions pe ON pr.[principal_id]
 | = pe.[grantee_principal_id] WHERE pr.[type_desc] = 'WINDOWS_GROUP' AND pr.
 | [type_desc] = 'WINDOWS_GROUP' AND pr.[name] like
 | CAST(SERVERPROPERTY('MachineName') As nvarchar) + '%';
4 | -- should not return any rows
```

## 11. 确保 msdb 数据库中的 public 角色没有被授予访问 SQL Agent 代理的权力

msdb 数据库中的 public 角色包含了每一个用户。SQL Agent 代理定义了一个可以在其中运行作业步骤的安全上下文。

```
1 USE [msdb]
2 GO
3 SELECT sp.name AS proxyname FROM dbo.sysproxylogin spl JOIN
 sys.database_principals dp ON dp.sid = spl.sid JOIN sysproxies sp ON
 sp.proxy_id = spl.proxy_id WHERE principal_id = USER_ID('public');
4 GO
5 -- should not return any rows
```

## 0x04 密码策略

1. 确保对于所有SQL认证登录来说 MUST\_CHANGE 选项值为 ON 【建议】

开启该选项时，SQL Server将在首次使用新的或更改的用户名时提示输入新的密码

```
1 SSMS -> Object Explorer, connect -> Security -> Logins -> right click on login
 -> Properties
```

2. 确保对于所以以 sysadmin 角色进行SQL认证登录来说 CHECK\_EXPIRATION 选项值为 ON

定期更换密码

```
1 SELECT l.[name], 'sysadmin membership' AS 'Access_Method' FROM sys.sql_logins
 AS l WHERE IS_SRVROLEMEMBER('sysadmin',name) = 1 AND l.is_expiration_checked
 <> 1
2 UNION ALL
3 SELECT l.[name], 'CONTROL SERVER' AS 'Access_Method' FROM
4 sys.sql_logins AS l JOIN sys.server_permissions AS p ON l.principal_id =
 p.grantee_principal_id WHERE p.type = 'CL' AND p.state IN ('G', 'W') AND
 l.is_expiration_checked <> 1;
5 -- should not return any rows
```

3. 确保对于所有SQL认证登录来说 CHECK\_POLICY 选项值为 ON

密码复杂性规则

```
1 SELECT name,is_disabled FROM sys.sql_logins WHERE is_policy_checked = 0;
```

## 0x05 审计和日志

1. 确保 Maximum number of error log files 值大于12

```
1 SSMS -> Object Explorer -> Management -> SQL Server Logs -> Configure
2 -- Or
3 DECLARE @NumErrorLogs int;
4 EXEC master.sys.xp_instance_regread
5 N'HKEY_LOCAL_MACHINE',
6 N'Software\Microsoft\MSSQLServer\MSSQLServer',
7 N'NumErrorLogs',
8 @NumErrorLogs OUTPUT;
9 SELECT ISNULL(@NumErrorLogs,-1) AS [NumberOfLogFiles];
```

## 2. 确保 Default Trace Enabled 服务器配置选项设置为 1

该选项提供包括账户创建, 权限提升和DBCC命令执行等数据库活动的审计日志,

```
1 SELECT name, CAST(value as int) as value_configured,
 CAST(value_in_use as int) as value_in_use FROM sys.configurations WHERE name
 = 'default trace enabled';
2 -- both value columns should show 1
```

## 3. 确保 Login Auditing 设置为 failed logins. 记录失败的登录

```
1 exec xp_loginconfig 'audit level';
2 -- should return failure
3 -- OR
4 SSMS -> right click on instance -> security
```

## 4. 确保 SQL Server Audit 设置为记录成功和失败的登录

```
1 SELECT
2 S.name AS 'Audit Name' ,
3 CASE S.is_state_enabled
4 WHEN 1 THEN 'Y'
5 WHEN 0 THEN 'N' END AS 'Audit Enabled' ,
6 S.type_desc AS 'Write Location' ,
7 SA.name AS 'Audit Specification Name' ,
8 CASE SA.is_state_enabled
9 WHEN 1 THEN 'Y'
10 WHEN 0 THEN 'N' END AS 'Audit Specification Enabled' ,
11 SAD.audit_action_name ,
12 SAD.audited_result
13 FROM sys.server_audit_specification_details AS SAD
14 JOIN sys.server_audit_specifications AS SA
15 ON SAD.server_specification_id = SA.server_specification_id
16 JOIN sys.server_audits AS S
17 ON SA.audit_guid = S.audit_guid
18 WHERE SAD.audit_action_id IN ('CNAU', 'LGFL', 'LGSD');
19 -- 应该返回三行, 分别有audit_change_group, failed_change_group以及
 successful_login_group
```

# 0x06 加密

## 1. 非系统数据库使用的对称加密算法为 AES\_128 或更高

```
1 USE <database_name>
2 GO
3 SELECT db_name() AS Database_Name, name AS Key_Name
4 FROM sys.symmetric_keys
5 WHERE algorithm_desc NOT IN ('AES_128', 'AES_192', 'AES_256')
6 AND db_id() > 4;
7 GO
8 -- should not return any rows
```

## 2. 非系统数据库使用的非对称加密密钥的大小不低于 2048



```

1 USE <database_name>
2 GO
3 SELECT db_name() AS Database_Name, name AS Key_Name
4 FROM sys.asymmetric_keys
5 WHERE key_length < 2048 AND db_id() > 4;
6 GO
7 -- should not return any rows

```

## 0x07 扩展存储

禁用不必要的扩展存储过程：

```

'xp_regdeletevalue'
'xp_regremovemultistring'
'xp_regwrite'
'xp_regaddmultistring'
'xp_regdeletekey'
'xp_enumerrorlogs'
'xp_enumgroups'
---不中视图中
'xp_loginconfig'
'xp_getfiledetails'
'xp_regenumvalues'
'sp_makewebtask'
---对应系统外围配置'xp_cmdshell'
'xp_cmdshell'
---对应系统外围配置'Ole Automation Procedures'
'Sp_OACreate'
'Sp_OADestroy'
'Sp_OAGetErrorInfo'
'Sp_OAGetProperty'
'Sp_OAMethod'
'Sp_OASetProperty'
'Sp_OAStop'

```

```

1 SELECT object_name,state from
 sys.system_components_surface_area_configuration
2 WHERE state=1 and object_name IN (
3 'xp_regdeletevalue',
4 'xp_regremovemultistring',
5 'xp_regwrite',
6 'xp_regaddmultistring',
7 'xp_regdeletekey',
8 'xp_enumerrorlogs',
9 'xp_enumgroups',
10 ---不中视图中
11 'xp_loginconfig',
12 'xp_getfiledetails',
13 'xp_regenumvalues',
14 'sp_makewebtask',
15 ---对应系统外围配置'xp_cmdshell'
16 'xp_cmdshell',
17 ---对应系统外围配置'Ole Automation Procedures'
18 'Sp_OACreate',

```

```
19 'Sp_OADestroy',
20 'Sp_OAGetErrorInfo',
21 'Sp_OAGetProperty',
22 'Sp_OAMethod',
23 'Sp_OASetProperty',
24 'Sp_OAStop'
25)
```

## (四) MySQL5.6部署规范

### 0x01 操作系统级别配置

1. 将数据库放在非系统分区

```
1 -- mysql
2 show variables where variable_name = 'datadir';
3 -- shell
4 df -h <datadir value>
```

2. 运行MySQL 守护进程的账户符合最小权限原则
3. 禁用MySQL命令历史记录

```
1 find / -name ".mysql_history"
```

4. 确保 `MYSQL_PWD` 环境变量没有被使用

MySQL可以通过这个环境变量读取默认的数据库密码

```
1 grep MYSQL_PWD /proc/*/environ
```

5. 确保运行MySQL数据库的用户 `mysql` 不能登录系统

```
1 getent passwd mysql | egrep "^\.[^\|]*[/bin/false|/sbin/nologin]$"
2 # 应该有输出
```

6. 确保用户的 `profile` 文件中没有设置 `MYSQL_PWD` 变量

```
1 grep MYSQL_PWD /home/*/{bashrc,profile,bash_profile}
2 # 应该没有输出
```

### 0x02 安装和计划任务

1. 为数据库创建备份计划

```
1 crontab -l
2 # 应该有输出
```

2. 验证数据库的备份计划能够正常运行
3. 确保数据库的备份文件应该被安全保护

- 是否被加密存储
- 是否离线存储
- 是否只有特定用户可以读取备份文件

#### 4. 开启binlogs

```
1 show variables like "%log_bin%";
2 -- result
3 log_bin ON
4 log_bin_basename ...
5 log_bin_index ...
```

#### 5. 制定灾难恢复计划

#### 6. 对配置文件和相关文件进行备份

- 配置文件(my.cnf)
- SSL证书文件
- UDF文件
- 自定义的源代码

#### 7. 使用专用服务器运行MySQL数据库

#### 8. 不在命令行中显示输入密码

如: `mysql -u admin -ppasswd [X]`

#### 9. 每个应用应该有自己的账户

## 0x03 权限设置

#### 1. 确保 `datadir` 目录下的文件有合适的权限

- 文件权限不高于700
- 文件属主及属组为 `mysql:mysql`

#### 2. 确保 `log_bin_basename` 文件有合适的权限

- 文件权限不高于660
- 文件属主及属组为 `mysql:mysql`

#### 3. 确保 `log_error` 文件有合适的权限

- 文件权限不高于660
- 文件属主及属组为 `mysql:mysql`

#### 4. 确保 `slow_query_log` 有合适的权限

- 文件权限不高于660
- 文件属主及属组为 `mysql:mysql`

#### 5. 确保 `relay_log_basename` 有合适的权限

- 文件权限不高于660
- 文件属主及属组为 `mysql:mysql`

#### 6. 确保 `general_log_file` 有合适的权限

- 文件权限不高于660
- 文件属主及属组为 `mysql:mysql`

## 7. 确保 `ssl_key` 文件有合适的权限

- 文件权限不高于400
- 文件属主及属组为 `mysql:mysql`

## 8. 确保 `plugin_dir` 目录下的文件有合适的权限

- 文件权限为775或755
- 文件属主或属组为 `mysql:mysql`

# 0x04 常规设置

## 1. 确保没有安装 `test` 数据库

```
1 show databases like 'test';
2 -- should return any rows
```

## 2. 确保没有使用 `allow-suspicious-udfs`

- 启动mysqld时, 不使用 `--allow-suspicious-udfs`
- mysql的配置文件中没有 `allow-suspicious-udfs=1`

## 3. 确保没有开启 `local_infile`

开启后, 可以从文件中导入数据

```
1 show variables like 'local_infile';
```

## 4. 确保启动 `mysqld` 时没有使用 `--skip-grant-tables`

开启后, 任何用户可不验证身份直接进入数据库

- 确保mysql的配置文件中没有 `skip-grant-tables` 或 `skip-grant-tables=FALSE`
- 确保启动 `mysqld` 时没有使用 `--skip-grant-tables`

## 5. 确保使用了 `--skip-symbolic-links`

- 确保MySQL的配置文件中 `skip_symbolic-links=YES` 或者 `'symbolic-links=0'`

## 6. 确保 `secure_file_priv` 非空

用来限制数据导入和导出操作。

- `secure_file_priv`为null 表示不允许导入导出
- `secure_file_priv`指定文件夹时, 表示mysql的导入导出只能发生在指定的文件夹
- `secure_file_priv`没有设置时, 则表示没有任何限制

```
1 show global variables where variable_name = 'secure_file_priv' and value <>
 '';
2 -- should contain a valid path
```

## 7. 确保 `sql_mode` 包含 `STRICT_ALL_TABLES`

模式会影响 MySQL 支持的 SQL语法以及它执行的数据验证检查, 即`sql_mode` 决定了哪些 SQL 语句可以被执行, 哪些不能被执行

```
1 show variables like 'sql_mode';
2 -- should contain STRICT_ALL_TABLES
```

## 0x05 MySQL权限

### 1. 确保只有管理员用户拥有访问所有数据库的权限

```
1 select user,host
2 FROM mysql.user
3 WHERE (Select_priv = 'Y')
4 OR (Insert_priv = 'Y')
5 OR (Update_priv = 'Y')
6 OR (Delete_priv = 'Y')
7 OR (Create_priv = 'Y')
8 OR (Drop_priv = 'Y');
9
10 select user,host
11 FROM mysql.db
12 WHERE db='mysql'
13 AND((Select_priv = 'Y')
14 OR (Insert_priv = 'Y')
15 OR (Update_priv = 'Y')
16 OR (Delete_priv = 'Y')
17 OR (Create_priv = 'Y')
18 OR (Drop_priv = 'Y'));
19 -- 确保上面返回的用户是管理员用户
```

### 2. 确保对于非管理员用户的 file\_priv 权限没有设置为 Y

file\_priv 权限决定该用户是否可以读写存在于服务器上的文件

```
1 select user,host from mysql.user where file_priv='Y';
2 -- 确保返回的用户都是管理员用户
```

### 3. 确保对于非管理员用户的 process\_priv 权限没有设置为 Y

该权限决定该用户是否能够查看所有会话的语句执行信息

```
1 select user,host from mysql.user where process_priv = 'Y';
2 -- 确保返回的用户都是管理员用户
```

### 4. 确保对于非管理员用户的 super\_priv 权限没有设置为 Y

该权限控制该用户是否能使用如下特性：

- change master to, kill, mysqladmin kill, purge binary logs, set global, mysqladmin debug
- 登录控制
- 以及更多

```
1 select user,host from mysql.user where super_priv = 'Y';
2 -- 确保返回的用户都是管理员用户
```

### 5. 确保对于非管理员用户的 shutdown\_priv 权限没有设置为 Y

该权限决定该用户是否能够使SQLServer服务器关机

```
1 select user,host from mysql.user where shutdown_priv = 'Y';
2 -- 确保返回的用户都是管理员用户
```

#### 6. 确保对于非管理员用户的 create\_user\_priv 权限没有设置为 Y

该权限控制该用户是否能创建删除用户、重命名用户名以及撤销已存在用户的权限

```
1 select user,host from mysql.user where create_user_priv = 'Y';
2 -- 确保返回的用户都是管理员用户
```

#### 7. 确保对于非管理员用户的 grant\_priv 权限没有设置为 Y

该权限决定该用户是否能控制其他用户的权限

```
1 select user,host from mysql.user where grant_priv = 'Y';
2 select user,host from mysql.db where grant_priv = 'Y';
3 -- 确保返回的用户都是管理员用户
```

#### 8. 确保对于非管理员用户的 repl\_slave\_priv 权限没有设置为 Y

该权限决定该用户是否能请求在主数据库上已完成的更新

```
1 select user,host from mysql.user where repl_slave_priv = 'Y';
2 -- 确保返回的用户都是管理员用户
```

#### 9. 确保用户只能在特定的数据库上进行 DML/DDl 操作

```
1 SELECT User,Host,Db
2 FROM mysql.db
3 WHERE Select_priv='Y'
4 OR Insert_priv='Y'
5 OR Update_priv='Y'
6 OR Delete_priv='Y'
7 OR Create_priv='Y'
8 OR Drop_priv='Y'
9 OR Alter_priv='Y';
```

## 0x06 审计和日志

#### 1. 确保 log\_error 值非空

该设置为用来记录错误信息的日志文件

```
1 show variables like 'log_error';
```

#### 2. 确保日志文件存储在非系统分区

```
1 select @@global.log_bin_basename;
```

#### 3. 确保 log\_warnings 值为 2

该变量用来控制记录日志的等级。1 为记录warning的日志，2 会记录更多的信息

```
1 | show global variables like 'log_warnings';
```

#### 4. 确保开启了审计日志

MySQL社区版不提供审计功能，需要使用第三方审计工具

#### 5. 确保 log-raw 值为 OFF

该设置决定是否在日志文件中明文记录密码

```
1 | 检查mysql的配置文件中是否有 log-raw = OFF
```

## 0x07 身份认证

#### 1. 确保 old\_passwords 值不为 1 或 ON

该值用来决定保存密码的hash函数：

- 0：使用 `mysql_native_password`
- 1：使用 `mysql_old_password`
- 2：使用 `sha256_password`

```
1 | show variables like 'old_passwords';
```

#### 2. 确保 secure\_auth 值为 ON

该选项决定服务器是否拒绝以 `mysql_old_password` 格式存储密码的账户的连接

```
1 | show variables like 'secure_auth';
```

#### 3. 确保密码没有存储在全局配置文件中

确保mysql配置文件中没有设置 `password`

#### 4. 确保 sql\_mode 值包含 NO\_AUTO\_CREATE\_USER

该选项可以防止没有提供认证信息的自动创建用户的 `GRANT` 语句的执行

```
1 | select @@global.sql_mode
2 | select @@session.sql_mode
3 | -- each result should contain NO_AUTO_CREATE_USER
```

#### 5. 确保所有的MySQL账户都有密码

```
1 | select user,host
2 | FROM mysql.user
3 | WHERE (plugin IN ('mysql_native_password','mysql_old_password','') AND
4 | (LENGTH(authentication_string) = 0 OR authentication_string IS NULL)) OR
5 | (plugin='sha256_password' AND LENGTH(authentication_string) = 0);
6 | -- should not return any rows
```

#### 6. 确保设置了密码策略

```

1 show variables like 'validate_password%';
2 -- 因该包含以下语句:
3 validate_password_length 应该大于14
4 validate_password_mixed_case_count 应该大于1
5 validate_password_number_count 应该大于1
6 validate_password_special_char_count 应该大于1
7 validate_password_policy 应该为medium或strong

```

7. 确保用户能登录的host没有使用通配符

```

1 select user,host from mysql.user where host = '%';
2 -- should not return any rows

```

8. 确保不存在匿名用户

```

1 select user,host from mysql.user where user = '';

```

## (五) 中间件部署规范

### 0x01 Nginx安全部署规范

#### 1. 隐藏版本号

```

1 http {
2 server_tokens off;
3 }

```

#### 2. 开启HTTPS

`ssl on`:开启https

`ssl_certificate`:配置nginx ssl证书的路径

`ssl_certificate_key`:配置nginx ssl证书key的路径

`ssl_protocols`:指定客户端建立连接时使用的ssl协议版本

`ssl_ciphers`:指定客户端连接时所使用的加密算法

```

1 server {
2 listen 443;
3 server_name <xxx>;
4
5 ssl on;
6 ssl_certificate <pem路径>;
7 ssl_certificate_key <key路径>;
8 ssl_protocols TLSv1 TLSv1.1 TLSv1.2;
9 ssl_ciphers HIGH:!aNULL:!MD%
10
11 }

```

#### 3. 限制请求方法



`$request_method`能获取到请求时所使用的method，应该配置只使用GET/POST方法访问，其他的method返回405

```
1 if ($request_method !~ ^(GET|POST)$){
2 return 405;
3 }
```

## 4. 拒绝某些User-Agent

禁止一些爬虫的扫描

```
1 if ($http_user_agent ~* LWP::Simple|BBBike|wget|curl){
2 return 444;
3 }
```

## 5. 利用referer图片防盗链

```
1 locations /images/ {
2 valid_referers none blocked <domain_name> <domain_name>;
3 if ($invalid_referer){
4 return 403;
5 }
6 }
```

`valid_referers`:验证referer

none: 允许referer为空

blocked: 允许不带协议的请求

## 6. 控制并发连接数

```
1 http {
2 limit_conn_zone $binary_remote_addr zone=ops:10m;
3 limit_conn_zone $server_name zone=coffee:10m;
4
5 server {
6 listen 80
7 server_name <server_name>;
8 ...
9 location / {
10 limit_conn opos 10; # 限制单一IP来源的连接数为10
11 limit_conn coffee 2000; # 限制单一虚拟服务器的总连接数为2000
12 limit_rate 500k; # 限制单个连接使用的带宽
13 }
14 }
15 }
```

`limit_conn_zone`:设定保存各个属性状态的共享内存空间的参数

- `limit_conn_zone <属性> zone=<空间名称>:<大小>`

`limit_conn`:为已经设定zone的属性设置最大连接数

## 7. 设置缓冲区大小防止缓冲区溢出攻击

```
1 client_body_buffer_size 1k;
2 client_header_buffer_size 1k;
3 client_max_body_size 1k;
4 large_client_header_buffers 2 1k;
```

`client_body_buffer_size`:默认8k或16k, 标识客户端请求body占用缓冲区的大小。如果连接请求超过指定缓冲区大小的值, 尼玛这些请求实体的整体或者部分将尝试写入一个临时文件

`client_header_buffer_size`:表示客户端请求头部的缓冲区大小。绝大多数情况下一个请求头不会大于1K, 如果大于1K, Nginx将分配给它一个更大的缓冲区, , 这个值可以在 `large_client_header_buffers` 中设置

`client_max_body_size`:标识客户端请求的最大可接受的body大小。如果请求头部的Content-Length字段的值大于该值, 客户端将收到一个(413)状态码的错误。【会影响上传文件的功能】

`large_client_header_buffers`:表示一些比较大的请求头使用的缓冲区数量和大小, 默认一个缓冲区大小为操作系统中分页文件大小, 通常是4k或8k。请求字段不能大于一个缓冲区的大小, 若大于, 则nginx将返回400状态码的错误

## 设置超时时间

```
1 client_body_timeout 10
2 client_header_timeout 10;
3 keepalive_timeout 5 5;
4 send_timeout 10;
```

`client_body_timeout`: 表示读取请求body的超时时间, 如果连接超过这个时间而客户端没有任何响应, Nginx将返回“**Request time out**” (408)错误

`client_header_timeout`: 表示读取客户端请求头的超时时间, 如果连接超过这个时间而客户端没有任何响应, Nginx将返回“**Request time out**” (408)错误

`keepalive_timeout`: 参数的第一个值表示客户端与服务器长连接的超时时间, 超过这个时间, 服务器将关闭连接, 可选的第二个参数参数表示Response头中Keep-Alive: timeout=time的time值, 这个值可以使一些浏览器知道什么时候关闭连接, 以便服务器不用重复关闭, 如果不指定这个参数, nginx不会在应Response头中发送Keep-Alive信息

`send_timeout`: 表示发送给客户端应答后的超时时间, Timeout是指没有进入完整 **established** 状态, 只完成了两次握手, 如果超过这个时间客户端没有任何响应, nginx将关闭连接

## 8. 添加Header头防止XSS攻击

```
1 add_header X-Frame-Options "SAMEORIGIN";
2 add_header X-XSS-Protection "1; mode=block";
3 add_header X-Content-Type-Options "nosniff";
```

`X-Frame-Options`:标识是否允许浏览器加载frame等属性。

- DENY: 禁止任何网页被嵌入
- SAMEORIGIN: 只允许本网站的嵌套
- ALLOW-FROM: 允许指定地址的嵌套

`X-XSS-Protection`:启用XSS过滤。mode=block标识若检查到XSS攻击则停止渲染页面

`X-Content-Type-Options`:用来指定浏览器对未指定或错误指定Content-Type资源真正类型的猜测行为

- nosniff: 标识不允许任何猜测
- 在通常的请求相应中, 浏览器会根据Content-Type来分辨响应的类型, 如果响应类型未指定或错误指定时, 浏览器会启用 `MIME-sniffing` 来猜测资源的响应类型

## 9. 添加其他Header头

```
1 add_header Content-Security-Policy "default-src 'self'";
2 add_header Strict-Transport-Security "max-age=31536000; includeSubDomains";
```

`Content-Security-Policy`: 表示页面可以加载哪些资源

- default-src: 定义针对所有类型的资源的默认加载策略。 `self` 表示允许来自想用来源的内容

`Strict-Transport-Security`: 表示告诉浏览器要用HTTPS协议代替HTTP来访问目标站点

- 当用户第一次访问目标站点后, 会返回一个包含了 `Strict-Transport-Security` Header的响应, 这个header告诉浏览器, 在接下来的 31536000 秒内, 对当前网站的所有请求都要使用 `https` 来访问。
- `includeSubDomains`: (可选), 表示对所有子域名也采用相同的规则

## 0x02 Tomcat安全部署规范

### 1. 更改Server Header

```
1 <Connector port="8080" server="webserver" />
```

### 2. 保护telnet管理端口

- 修改默认的8005管理端口或禁用
- 修改 `SHUTDOWN` 命令为其他字符串

若开启, 则可以使用nc或者telnet发送指令直接关闭tomcat

```
1 <Server port="8578" shutdown="close" > # 更改
2 <Server port="-1" shutdown="close" > # 禁用
```

### 3. 保护AJP连接端口

- 修改或禁用默认的AJP8009端口, 但配置在8000-8999之间

```
1 <Connector port="8349" protocol="AJP/1.3" /> # 修改
2 <!--<Connector port="8349" protocol="AJP/1.3" /> --> # 禁用
```

### 4. 删除默认文档和示例程序

- 删除默认的 `$CATALINA_HOME/conf/tomcat-users.xml` 文件
- 删除 `$CATALINA_HOME/webapps` 下默认的所有目录和文件
- 将tomcat应用根目录配置为tomcat安装目录以外的目录

### 5. 隐藏版本信息 (需要解jar包)

针对该信息的显示是由一个jar包控制的, 该jar包存放在\$CATALINA\_HOME/lib目录下, 名称为 catalina.jar, 通过 jar xf 命令解压这个jar包会得到两个目录 META-INF 和 org, 修改 org/apache/catalina/util/ServerInfo.properties 文件中的 serverinfo 字段来实现更改 tomcat版本信息的目的

```
1 cd $CATALINA_HOME/lib
2 jar xf catalina.jar
3 cat org/apache/catalina/util/ServerInfo.properties |grep -v "^$|#"
4 mkdir -p org/apache/catalina/util
5 vim ServerInfo.properties
6 server.info=<其他值>
```

## 6. 专职低权限用户启动tomcat

- 创建专门的用户来启动tomcat
- 限制该用户访问目录的权限
- 将Tomcat和web项目的属主分离

## 7. 文件列表访问控制

- 不列出文件列表

```
1 # 修改$CATALINA_HOME/conf/web.xml文件
2 # 配置default部分的listings字段的值为false
3 <param-name>listings</param-name>
4 <param-name>>false</param-name>
```

## 8. 脚本权限回收

- \$CATALINA\_HOME/bin 目录下的 start.sh, catalina.sh, shutdown.sh 的权限不高于744

```
1 chmod -R 744 $CATALINA_HOME/bin/*
```

# 0x03 Apache安全部署规范

## 1. 专职低权限用户运行Apache服务

- 创建专门的用户和组来启动Apache

```
1 groupadd apache
2 useradd apache -g apache
3 # httpd.conf
4 User apache
5 Group apache
6
```

## 2. 目录访问权限设置

### 2.1 非超级用户不能修改Apache主目录中的内容

```
1 # httpd.conf
2 ServerRoot /usr/local/apache # 主目录
3
```

## 2.2 配置文件和日志文件权限

- 配置文件 `/etc/httpd/conf/httpd.conf` 的权限不高于 600
- 日志文件 `/var/log/httpd/*.log` 日志文件的权限不高于644

# 3. 日志设置

## 3.1 错误日志

```
1 LogLevel notice # 日志的级别
2 ErrorLog / .../logs/error_log
3
```

## 3.2 访问日志

```
1 LogFormat %h %l %u %t \"%r\" %>s %b \"%{Accept}i\" \"%{Referer}i\" \"%{User-Agent}i\"
2 combined
3 CustomLog / .../logs/access_log combined
4
```

`ErrorLog`: 设置错误日志文件名和位置。

`CustomLog`: 指定保存日志文件的具体位置和日志的格式。

`LogFormat`: 设置日志格式, 建议设置为combined格式

`LogLevel`: 用于调整记录在错误日志中的信息的详细程度

# 4. 只允许访问web目录下的文件

- 不能访问web目录之外的任何文件

```
1 # httpd.conf
2 Order Allow,Deny
3 Allow from /web # /web为网站根目录
4
```

# 5. 禁止列出目录

- 禁止Apache列表显示文件

```
1 # httpd.conf
2 # Options Indexes FollowSymLinks
3 Options FollowSymLinks # 删去Indexes
4
```

# 6. 防范拒绝服务

- 合理设置Session时间, 防止拒绝服务攻击

```
1 # httpd.conf
2 Timeout 10
3 KeepAlive On
4 KeepAliveTimeout 15 # 限制每个session的保持时间为15秒。
5
```

## 7. 隐藏版本号

```
1 # httpd.conf
2 ServerSignature Off
3 ServerTokens Prod
4
```

## 8. 关闭TRACE功能

```
1 # httpd.conf
2 TraceEnable Off
3
```

## 9. 绑定监听地址

```
1 # httpd.conf
2 Listen <ip>:<port>
3
```

## 10. 删除默认安装的无用文件

### 10.1 删除默认的html文件

```
1 rm -rf /usr/local/apache2/htdocs/*
2
```

### 10.2 删除默认的CGI脚本

```
1 rm -rf /usr/local/apache2/cgi-bin/*
2
```

### 10.3 删除Apache的说明文件

```
1 rm -rf /usr/local/apache2/manual
2
```

### 10.4 删除源代码文件

```
1 rm -rf /path/to/httpd-2.2.4*
2
```

## 11. 限定可以使用的HTTP方法

- 禁用PUT,DELETE等危险的HTTP方法

- 只允许GET, POST方法

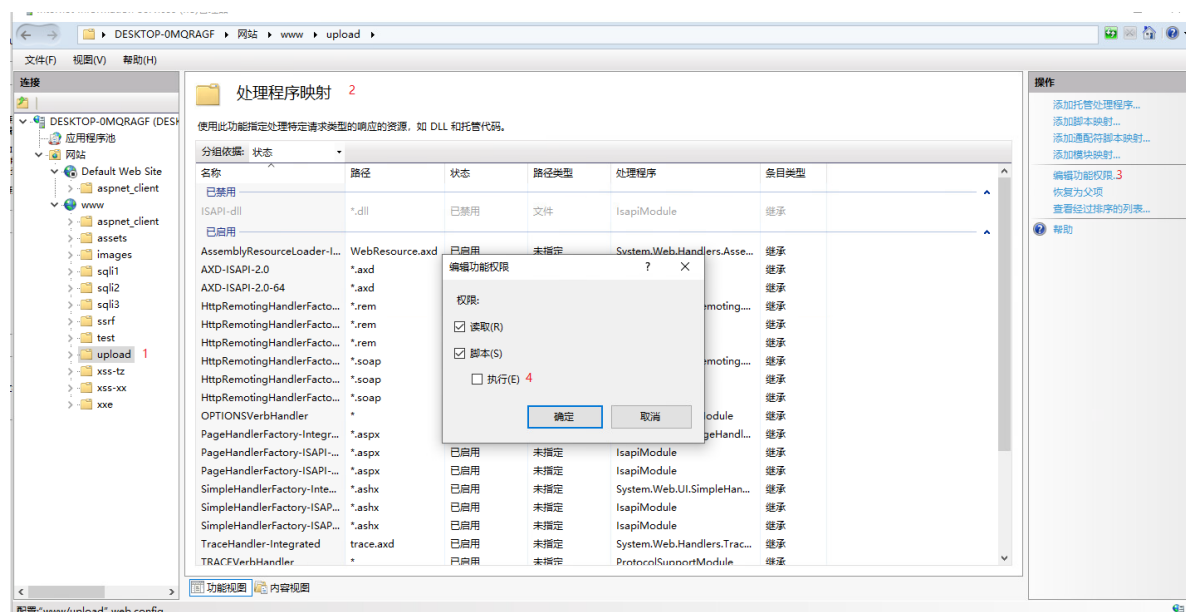
```
1 # httpd.conf
2 <Location />
3 <LimitExcept GET POST CONNECT OPTIOINS>
4 Order Allow,Deny
5 Deny from all
6 </LimitExcept>
7 </Locatioin>
8
```

## 0x04 IIS安全部署规范

### 1. 限制目录的执行权限

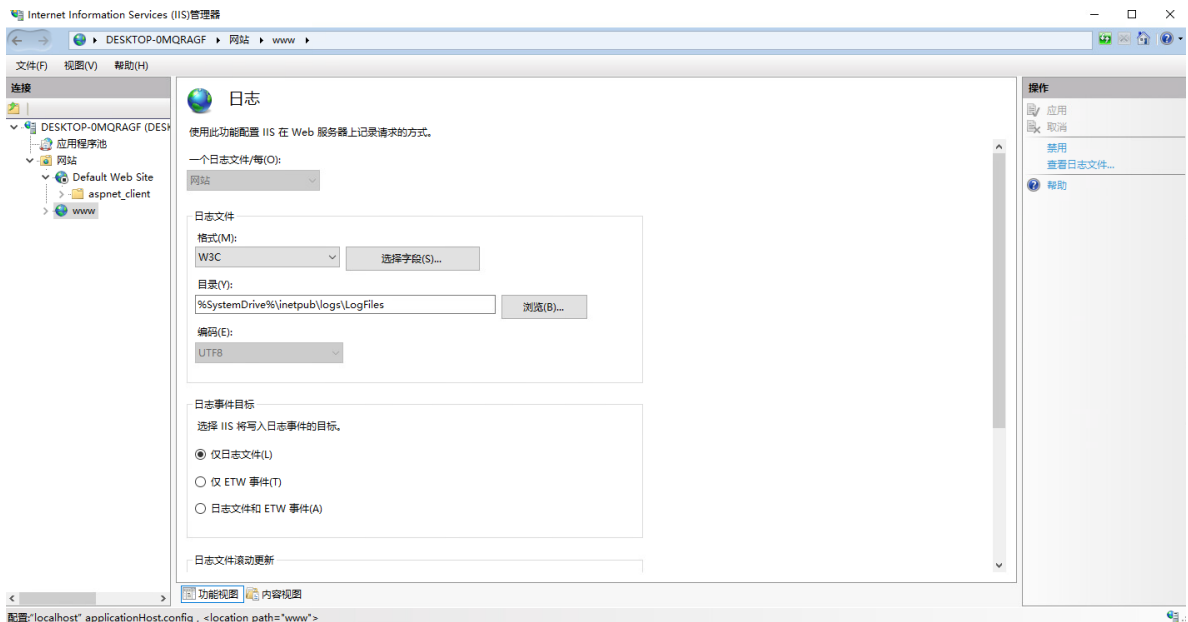
- 在存储上传文件的地方, 限制脚本的执行

可以做到即使上传了shell文件, 也无法解析执行



### 2. 开启日志记录功能

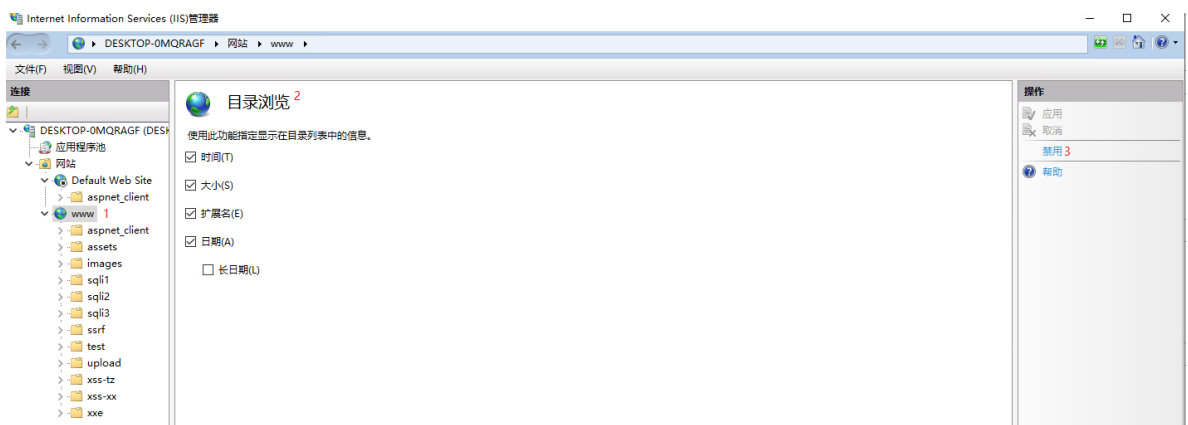
- 开启日志记录功能
- 设置日志文件的权限



### 3. 自定义错误页面

- 防止泄露一些包括网站具体路径的信息

### 4. 关闭目录浏览功能



### 5. 停用或删除默认站点

- 删除IIS安装时默认的 default web site

### 6. 删除不必要的脚本映射

- 只保留需要的脚本映射

### 7. 专职低权限用户运行网站

- 创建一个权限比较低的用户来运行网站

### 8. 在独立的应用程序池中运行网站

- 若同一台IIS中运行多个网站，可以每个网站都运行在单独的应用程序池中

## 0x05 Redis安全部署规范

### 1. 专职低权限用户启动redis



- 创建专门的redis用户和组来运行redis

## 2. 限制redis配置文件的访问权限

- redis配置文件 `redis.conf` 的权限不高于600

## 3. 更改默认端口

- 修改6379端口为其他端口

```
1 # redis.conf
2 port 8379
3
```

## 4. 开启redis密码认证

- 在 `redis.conf` 配置文件中，使用requirepass开启密码认证

## 5. 禁用或者重命名危险命令

- 应当禁用或重命名以下命令

```
1 # redis.conf
2 rename-command FLUSHALL ""
3 rename-command FLUSHDB ""
4 rename-command CONFIG ""
5 rename-command KEYS ""
6 rename-command SHUTDOWN ""
7 rename-command DEL ""
8 rename-command EVAL ""
```

## 6. 禁止监听在公网IP

- 禁止redis监听在 `0.0.0.0` 或公网IP

```
1 # redis.conf
2 bind 127.0.0.1
3 # OR
4 bind <内网IP>
```

## 7. 开启保护模式

- 开启保护模式

开启保护模式后，若没有指定bind和密码，则只能本地访问redis

```
1 # redis.conf
2 protected-mode yes
```

# 0x06 RabbitMQ规范

## 1. 专职低权限用户启动RabbitMQ

- 创建专门的用户和组来启动RabbitMQ

## 2.配置SSL证书

- rabbitmq.config中添加ssl\_listeners和ssl\_options配置项

## 3. 开启HTTP后台认证

- 启用 HTTP 后台认证需要使用 rabbitmq\_auth\_backend\_http 插件
- 配合 rabbitmq\_auth\_backend\_cache 通过缓存减轻授权认证服务器压力

```
1 # sudo rabbitmqctl environment
2 # sudo cat /etc/rabbitmq/enabled_plugins
```

## 4. 删除或修改默认的guest用户和密码

```
1 sudo rabbitmqctl list_users
2 # 检查是否有默认用户名guest
```

## 5. RabbitMQ的web ui插件存在一些安全漏洞

- 若不需要web界面，可以关闭相应插件：`./rabbitmq-plugins disable rabbitmq_management`